VULNERABILITY ASSESSMENT REPORT FOR A LIVE WEBSITE

Mkhonta Nhlosenhle
09/03/26

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY 3
2. METHODOLOGY 3
3. FINDINGS & RISK CLASSIFICATION 3
4. RISK PRIORITIZATION 4
5. REMEDIATION ROADMAP 4
6. CONCLUSION 5
7. APPENDIX 5

1. Executive Summary
Client Website: https://www.immuniweb.com/
Date of Audit: 09/03/2026
Auditor: Mkhonta Nhlosenhle
Purpose: Evaluate the security posture of the website using passive, non-intrusive methods.
Scope: Public-facing pages only, no exploitation or harmful testing.

2. Methodology
Tools Used:
Nmap (basic port exposure)
OWASP ZAP (passive scan)
Browser DevTools (headers, cookies, visible components)
Approach: Passive observation, configuration review, and documentation.

3. Findings & Risk Classification

Issue	Description	Why It Matters	Risk	Fix
Open Port 80 (HTTP)	Website allows unencrypted	Data can be intercepted	High	Redirect all traffic to HTTPS
Open Port 443 (HTTPS)	Secure traffic supported	Needs proper SSL/TLS confi	Medium	Validate certificate,
Open Port 8080	Alternate HTTP port open	May expose test/admin	High	Restrict or disable if
Open Port 8443	Alternate HTTPS port	Could expose admin consoles	High	Restrict to internal users
SSL/TLS Configuration	SSL Labs test shows A+ rating	Strong encryption,	Low	Maintain current
No visible outdated	Page source does not	Reduces risk of targeted	Low	Continue using hashed asset
Use of third-party scripts	Google Tag Manager and	May introduce tracking or	Medium	Review third-party script
Missing CSP Header	No Content-Security-Policy	Increases risk of malicious	Medium	Add CSP header to
Cookie No HttpOnly Flag	Session cookies lack HttpOnly	Cookies can be stolen via	High	Add HttpOnly and Secure
Missing HSTS	No Strict-Transport-	Users may connect	Medium	Enable HSTS in server config
Server Version Info Leaked	Server header reveals	Helps attackers target known	Low	Disable server signature/bann

4. Risk Prioritization

High Priority:

o Open Port 80 (HTTP) → Unencrypted traffic can be intercepted.
o Open Port 8080 → May expose test/admin services.
o Open Port 8443 → Could expose admin consoles.
o Cookie No HttpOnly Flag → Session cookies vulnerable to theft via scripts.

· Medium Priority:

o Open Port 443 (HTTPS) → Needs proper SSL/TLS hardening (HSTS, cipher review).
o Missing CSP Header → Increases risk of malicious script injection.
o Missing HSTS → Users may connect insecurely if redirected from HTTP.
o Use of Third-Party Scripts → May introduce tracking or misconfiguration risks.

Low Priority:

o SSL/TLS Configuration (A+ rating) → Excellent, just maintain certificate renewals.
o No visible outdated components → Positive finding, continue best practices.
o Server Version Info Leaked → Information disclosure, but low risk.

5. Remediation Roadmap

Immediate (1-2 weeks): Redirect HTTP (Port 80) to HTTPS, Restrict or Disable Port 8080, Restrict or Disable Port 8443, Secure Cookies

Short Term (1 month): Enable HSTS (Strict-Transport-Security), - Add Content-Security-Policy (CSP), Review Third-Party Scripts

Ongoing: - Maintain SSL/TLS A+ Configuration, Disable Server Version Disclosure, Quarterly Security Reviews

6. Conclusion

This audit highlights key areas where the website can improve its security posture. Addressing the high-priority issues first will significantly reduce risk exposure. Continuous monitoring and regular updates are recommended to maintain a strong security baseline.

7. Appendix

Nmap scan logs (open ports)

```
Discovered open port 80/tcp on 104.26.1.240
Discovered open port 443/tcp on 104.26.1.240
Discovered open port 8080/tcp on 104.26.1.240
Discovered open port 8443/tcp on 104.26.1.240
```

SSL Labs full report pages

Qualys. SSL Labs

Home Projects Qualys Free Trial Contact

You are here: Home > Projects > SSL Server Test > www.immuniweb.com

SSL Report: www.immuniweb.com

Assessed on: Mon, 09 Mar 2026 05:03:13 UTC | Clear cache

Scan Another >>

	Server	Test time	Grade
1	2606:4700:20:0:0:0:681a:f0 Ready	Mon, 09 Mar 2026 04:58:50 UTC Duration: 44.214 sec	A+
2	2606:4700:20:0:0:0:681a:1f0 Ready	Mon, 09 Mar 2026 04:59:35 UTC Duration: 44.119 sec	A+
3	172.67.74.167 Ready	Mon, 09 Mar 2026 05:00:19 UTC Duration: 43.274 sec	A+
4	104.26.0.240 Ready	Mon, 09 Mar 2026 05:01:03 UTC Duration: 43.113 sec	A+
5	104.26.1.240 Ready	Mon, 09 Mar 2026 05:01:46 UTC Duration: 42.992 sec	A+
6	2606:4700:20:0:0:0:ac43:4aa7 Ready	Mon, 09 Mar 2026 05:02:29 UTC Duration: 43.186 sec	A+

SSL Report v2.4.1

Copyright © 2009-2026 Qualys, Inc. All Rights Reserved. Privacy Policy. Terms and Conditions

Try Qualys for free! Experience the award-winning Qualys Cloud Platform and the entire collection of Qualys Cloud Apps, including certificate security solutions.

ZAP alerts list

- Alerts (26)
  - CSP: Failure to Define Directive with No Fallback (Systemic)
  - CSP: Wildcard Directive
  - CSP: script-src unsafe-eval (Systemic)
  - CSP: script-src unsafe-inline
  - CSP: style-src unsafe-inline (Systemic)
  - Content Security Policy (CSP) Header Not Set (Systemic)
  - Cross-Domain Misconfiguration (11)
  - Missing Anti-clickjacking Header (Systemic)
  - Session ID in URL Rewrite (6)
  - Sub Resource Integrity Attribute Missing (3)
  - CSP: Notices
  - Cookie No HttpOnly Flag (3)
  - Cookie with SameSite Attribute None (7)
  - Cookie without SameSite Attribute
  - Cross-Domain JavaScript Source File Inclusion (2)
  - Server Leaks Version Information via "Server" HTTP Response Header Field (10)
  - Strict-Transport-Security Header Not Set (Systemic)
  - Timestamp Disclosure - Unix (Systemic)
  - X-Content-Type-Options Header Missing (Systemic)